CS 6530 Applied Cryptography

Security Objectives and Services

Foundations and Threat Modelling

START WITH THE REQUIRED SECURITY OUTCOME

A student says:

"Please encrypt the grades."

UNDESIRED OUTCOME → **POSITIVE SECURITY REQUIREMENT** → **MECHANISM LATER**

Undesired: An unauthorized student reads another student's grade.

Requirement: Only that student and authorized faculty shall read the grade.

Select mechanisms and controls only after stating the outcome.

REQUIREMENTS BEFORE MECHANISMS

A requirement states what must hold; a control or mechanism is one way to support it.

SECURITY REQUIREMENT

"Only authorized parties shall read the grade."

DESIGN CHOICE

"Use AES."

Pattern: asset + property + authorized parties + operation/state + conditions

One requirement may need several controls; one control may support several objectives.

LEARNING OUTCOMES

By the end, you should be able to:

- define confidentiality, integrity, and availability;
- distinguish authentication from authorization;
- explain accountability, auditability, and non-repudiation precisely;
- recognize privacy risks beyond content disclosure;
- separate objectives, services, and mechanisms; and
- state what cryptography supports directly—and what needs broader controls.

THE CIA TRIAD: A STARTING POINT

Attach every objective to an asset and context.

C

CONFIDENTIALITY

Who may learn it?

I

INTEGRITY

What change is allowed?

A

AVAILABILITY

When must it work?

Asset: anything of value that requires protection.

Authentication, authorization, privacy and accountability extend the picture.

CONFIDENTIALITY

Confidentiality restricts disclosure—but the requirement must be specific.

WHAT?

content • key • identity • location

HIDDEN FROM WHOM?

outsider • peer • operator • service

IN WHICH STATE?

at rest • in transit • in use

UNDER WHAT CONDITIONS?

role • purpose • time • context

DATA EXISTS IN MULTIPLE STATES

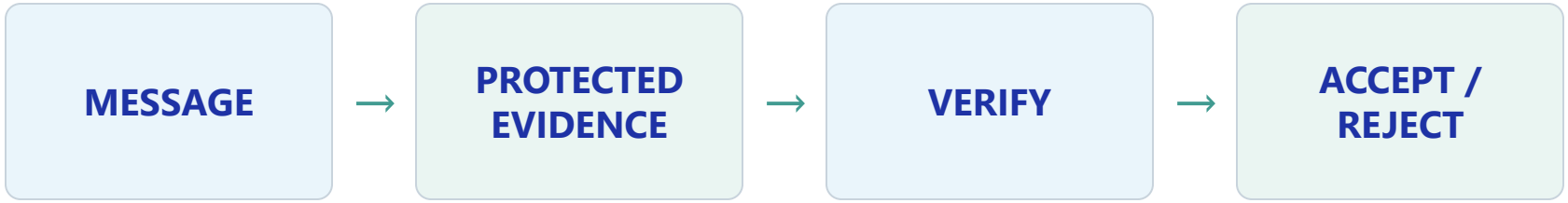
Protection requirements change with the state and exposure of the data.

AT REST	IN TRANSIT	IN USE	METADATA
files • databases backups • keys	traffic between endpoints	plaintext and secrets in memory	parties • timing volume • location

Content encryption does not automatically hide metadata—or protect compromised endpoints.

INTEGRITY

Integrity protects content, order, state and context against unauthorized or undetected change.



Payment example: verify amount + recipient + account + transaction context.

A plain hash sent beside a message is not adversarial integrity:
an attacker can replace both.

FRESHNESS AND REPLAY PROTECTION

The bits may be unchanged while the transaction is no longer acceptable.



Freshness evidence: nonces • counters • timestamps • transaction identifiers • replay windows

AVAILABILITY

Availability needs operational and architectural controls beyond cryptography.



Cryptography cannot create bandwidth, power, compute capacity or a functioning dependency.

CIA CLASSIFICATION ACTIVITY

Identify the primary objective—and justify any secondary objective.

Stolen decryption key	**C / I / A ?**
Valid payment replayed	**C / I / A ?**
Modified installer distributed	**C / I / A ?**
Authentication service overwhelmed	**C / I / A ?**
Backup key permanently lost	**C / I / A ?**

AUTHENTICITY AND AUTHENTICATION

Always qualify the claim: what, to whom, using which evidence, and for what purpose?

AUTHENTICITY

Is the entity, message or artifact what it claims to be?

Signed package: origin + integrity evidence tied to a verification key

AUTHENTICATION

Establishes a claimed identity or origin with defined assurance.

Certificate: server identity/key evidence
MAC: origin among shared-key holders

The claim must be precise before evidence can support it.

AUTHENTICATION CLAIMS ARE DIFFERENT

These claims are related—but they answer different questions.

ENTITY

Who is actively present?
Example: live server authentication

DATA ORIGIN

Where did the data originate?
Example: verify a MAC

INTEGRITY

Was the message altered?
Example: changed field is rejected

FRESHNESS

Is the evidence recent?
Example: nonce defeats replay

AUTHENTICATION IS NOT AUTHORIZATION

Knowing who is requesting an action does not decide whether that action is permitted.

AUTHENTICATION

Who or what is making the request?

≠

AUTHORIZATION

May this requester perform this action now?

Example: authenticating as a lecturer does not authorize changing every course's grades.

Permission may also depend on role, device, time, risk and purpose.

ACCOUNTABILITY, AUDITABILITY, NON-REPUDIATION

Evidence must be recorded, preserved and interpreted before it can support responsibility or dispute resolution.

AUDITABILITY

Can we examine reliable evidence?

→

ACCOUNTABILITY

Can action be traced responsibly?

→

NON-REPUDIATION

Can evidence help resolve a dispute?

Reliable conclusions also depend on protected logs, identity assurance, time, key custody and governance.

A DIGITAL SIGNATURE IS NOT THE WHOLE STORY

A signature establishes a narrow cryptographic fact; broader conclusions require additional evidence.

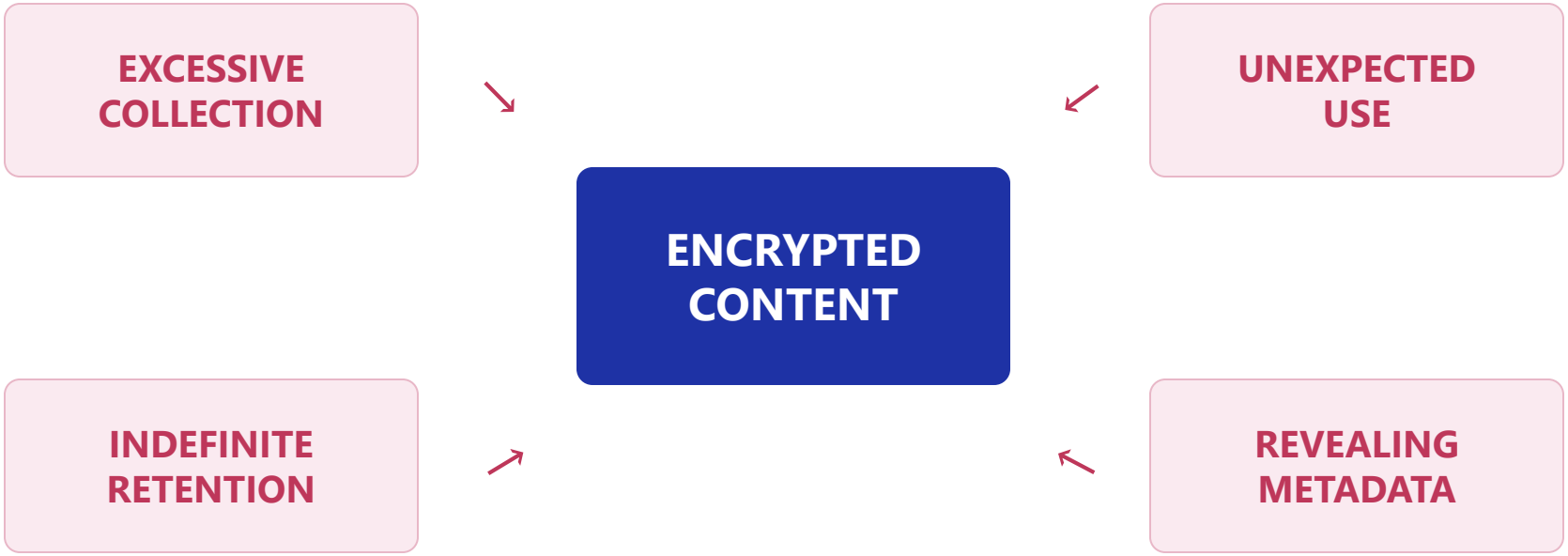
PRIVATE KEY SIGNED DATA → **VALID SIGNATURE** → **BROADER CONCLUSION?**

Also examine:
- Identity–key binding
- Key custody and revocation
- Exact signed context
- Trusted time and applicable procedure

A signature does not prove that the signed statement is true.

PRIVACY IS BROADER THAN CONFIDENTIALITY

Confidentiality limits disclosure; privacy also asks whether data practices are appropriate.



Privacy includes collection • use • disclosure • retention • inference

BEYOND CIA: RELATED SECURITY PROPERTIES

Each property is a separate claim with its own scope and assumptions.

FRESHNESS	Recent enough for purpose
REPLAY PROTECTION	Old valid data rejected
FORWARD SECRECY	Selected past sessions protected
ANONYMITY / UNLINKABILITY	Identity or actions not linked
SAFETY / RESILIENCE	Controlled failure and recovery